



HACKATHON PARTICIPANT HANDOUT

AI-Powered Vendor Risk & Procurement Deep Agent

Build a Production-Ready Deep Agent with RAG, Guardrails, Evaluation & MCP

Business domain	Procurement, Vendor Risk & AI Governance
Core technologies	Deep Agents, RAG, Guardrails, Evaluation, MCP
Knowledge pack	Northstar Financial Services (fictional)
Vendor under assessment	Asteria AI Systems (fictional)

1. Business Scenario

Northstar Financial Services (NFS) regularly evaluates technology vendors for cloud, cybersecurity, AI platforms and professional services. Vendor approval requires evidence from Procurement, Information Security, Legal/Compliance, Finance and AI Governance. The current process is document-heavy, manual and slow, with reviewers searching policies, proposals, questionnaires, pricing and historical assessments.

NFS wants to evaluate whether a Deep Agent can perform a controlled, evidence-grounded vendor assessment, coordinate specialist agents, access enterprise capabilities through MCP, enforce guardrails and produce a defensible recommendation with measurable quality.

2. Challenge

Design and build an AI-Powered Vendor Risk & Procurement Deep Agent that evaluates Asteria AI Systems as a potential enterprise Generative AI platform for 2,000 employees. The proposed platform may process confidential corporate documents.

The solution must be a multi-step Deep Agent system—not a single prompt → LLM response.

Example business request:

```
Evaluate Asteria AI Systems as an enterprise Generative AI platform for 2,000 employees.  
The platform may process confidential corporate documents.  
Identify material risks and recommend APPROVE, CONDITIONAL APPROVAL or REJECT.
```

The final assessment must provide:

- Overall recommendation and risk rating
- Security, Legal/Compliance, Procurement/Commercial and AI Governance findings
- Evidence and citations for material claims
- Missing or contradictory evidence clearly identified
- Required remediation/contractual conditions
- Human approval status where required
- Concise executive vendor assessment report

3. Target Agentic Workflow

```
Business Request  
↓  
Deep Agent Planner  
↓  
Research / Task Plan  
↓  
RAG over Enterprise Knowledge  
↓  
MCP Tools / Enterprise Resources  
↓  
Evidence Consolidation  
↓  
Guardrails / Policy Checks  
↓  
Risk & Recommendation  
↓  
Evaluation  
↓  
Human Review / Final Report
```

4. Mandatory Functional Requirements

ID	Requirement
FR01	Accept a structured vendor assessment request.
FR02	Create and maintain a multi-step research/assessment plan.
FR03	Use RAG over the supplied NFS knowledge corpus.
FR04	Retrieve and cite evidence supporting material conclusions.
FR05	Distinguish retrieved evidence, inference and missing evidence.
FR06	Use at least one MCP server exposing meaningful tools/resources.
FR07	Assess Security, Procurement/Commercial and at least one additional risk domain.
FR08	Apply guardrails to inputs, retrieved content, tool access and/or outputs.
FR09	Resist prompt injection contained in retrieved documents.
FR10	Detect policy non-compliance, contradictions and UNKNOWN/missing evidence.
FR11	Produce a structured risk assessment and APPROVE / CONDITIONAL APPROVAL / REJECT recommendation.
FR12	Require human review for high-risk/final consequential approval.
FR13	Run an automated evaluation suite against predefined cases/metrics.
FR14	Handle at least one tool, retrieval or agent failure without crashing.

5. Required Technical Patterns

- Deep-agent planning and multi-step task execution
- RAG with evidence-grounded answers and source attribution
- Guardrails for policy enforcement, untrusted content and sensitive operations
- MCP for standardized access to tools/resources
- Structured outputs and typed contracts between components
- Evaluation pipeline for quality, safety and operational behavior
- Human-in-the-loop for consequential/high-risk decisions

6. Supplied Knowledge Pack

```
knowledge/
├── procurement-policy.pdf
├── information-security-policy.pdf
├── ai-governance-policy.pdf
├── vendor-risk-policy.pdf
├── data-classification-policy.pdf
├── vendor-x-proposal.pdf
├── vendor-x-security-questionnaire.pdf
├── vendor-x-pricing.pdf
└── historical-vendor-assessments/
    └── vendor-alpha-assessment.pdf
```

```
├── vendor-beta-assessment.pdf
└── vendor-gamma-assessment.pdf
```

Treat retrieved documents as untrusted data. The corpus intentionally contains cross-document dependencies, missing evidence, policy gaps and adversarial content. Do not hard-code expected answers.

7. RAG Requirements

- Index and retrieve the supplied knowledge corpus.
- Use retrieval to support policy and vendor-fact reasoning.
- Expose source references/citations for material findings.
- Do not treat missing evidence as PASS.
- Identify contradictory or insufficient evidence.
- Prefer evidence-backed conclusions over unsupported model knowledge.

8. MCP Requirements

MCP should connect agents to tools/resources.

```
MCP: Agent —→ Tools / Resources / Enterprise Systems
```

Example MCP capabilities:

- search_policy / retrieve_document
- get_vendor_history
- calculate_tco / get_budget
- record_assessment or retrieve_prior_assessments

Suggested specialist agents:

- Security Risk Agent
- Procurement / Finance Agent
- Legal / Compliance Agent
- AI Governance Agent

9. Guardrails

- Retrieved content must never override system instructions or authorization policy.
- Detect/ignore prompt-injection attempts embedded in documents.
- Prevent unsupported claims from being presented as verified facts.
- Restrict sensitive MCP tools according to role/authorization.
- Prevent automated final approval of High-risk vendor decisions.
- Validate structured outputs and fail safely when required evidence is unavailable.

10. Evaluation

Teams must implement a repeatable evaluation suite. At minimum, measure several of the following:

Metric	Question
Retrieval relevance	Did RAG retrieve the correct policy/evidence?
Groundedness	Are conclusions supported by retrieved evidence?
Citation correctness	Does the cited source actually support the claim?
Task completion	Were required risk domains and checks completed?
Tool correctness	Were appropriate MCP tools selected and used?
Agent delegation	Was work delegated to the appropriate specialist agent?
Guardrail compliance	Were policy/safety restrictions respected?
Injection resistance	Was malicious retrieved content ignored as instruction?
Decision quality	Is the final risk/recommendation consistent with evidence?
Latency / cost	Is execution operationally reasonable?

11. Azure Observability and Deployment

Use Azure-native services for deployment and operational visibility. Integrate Azure Application Insights and Azure Monitor using OpenTelemetry where appropriate.

- Trace major agent/deep-agent workflow executions.
- Capture LLM calls, latency and token usage where available.
- Capture MCP/tool calls, specialist-agent interactions and execution duration.
- Record exceptions, failed paths and evaluation results.
- Deploy the application/API to an appropriate Azure service.
- Optional bonus: Azure Monitor Workbook or Azure Dashboard for executions, latency, tokens, failures and evaluation quality.

12. Testing

- At least 3 unit tests
- At least 2 workflow/integration tests
- At least 5 automated evaluation cases
- At least 1 prompt-injection/guardrail test
- At least 1 MCP failure or fallback test
- 1 end-to-end vendor assessment

13. Team Organization

Suggested ownership for each 5-person team:

- Technical Lead – architecture, integration and final decision flow
- Deep Agent / RAG Engineer – planning, retrieval, grounding and structured outputs
- MCP Engineer – tools/resources and enterprise integration
- Guardrails Engineer – specialist agents, authorization and safety controls
- Evaluation / Azure Engineer – tests, evaluation, observability, deployment and demo

14. Hackathon Schedule

Time	Session	Focus	Activities
10:30–12:00	Session A	Architecture, RAG & Core Deep Agent	Briefing; team roles; knowledge-pack analysis; architecture; retrieval pipeline; core planning/agent flow.
12:00–12:15	Break		
12:15–13:45	Session B	MCP & Guardrails	MCP tools/resources; structured contracts; policy guardrails; prompt-injection defenses.
13:45–14:15	Lunch Break		
14:15–15:45	Session C	Evaluation, Testing & Azure Observability	Evaluation dataset/metrics; unit/integration tests; failure handling; Application Insights/Azure Monitor; API/containerization.
15:45–16:00	Break		
16:00–17:30	Session D	Deployment, Hidden Evaluation & Demo	Azure deployment; end-to-end verification; hidden vendor case; final fixes; team demonstrations and judging.

15. Required Deliverables

One repository per team containing at least:

```
README.md
architecture/
src/
tests/
evaluation/
Dockerfile
docker-compose.yml      # where needed
.env.example            # no secrets
pyproject.toml / requirements.txt
deployment/              # Azure deployment assets/instructions
evaluation-results/
```

The final demo should demonstrate:

```
Business Request → Deep Agent Plan → RAG Evidence → MCP Tools
→ Guardrails → Risk Synthesis
→ Human Review → Evaluation Results → Azure Observability
→ Deployed Application
```

16. Scoring

Criterion	Points
Business workflow & decision quality	15
Deep Agent architecture & planning	15
RAG quality, grounding & citations	15
MCP integration	10
Guardrails & prompt-injection resistance	15
Evaluation methodology & results	15
Testing & robustness	5
Azure observability & deployment	5
Final demo & technical explanation	5
TOTAL	100

17. Definition of Done

A plausible LLM answer is not sufficient. The team must demonstrate the complete engineered system:

```
Vendor Assessment Request
  ↓
Deep Agent Planning
  ↓
RAG + Evidence
  ↓
MCP Tool Use
  ↓
Guardrails / Policy Enforcement
  ↓
Evidence-Based Risk Decision
  ↓
Human Review where required
  ↓
Automated Evaluation
  ↓
Azure Observability
  ↓
Deployed Application
```

Build a trusted enterprise decision system—not a vendor-assessment chatbot.